[LAW FIRM NAME]

INFORMATION SECURITY & PRIVACY POLICY

Confidentiality · Integrity · Availability · Privacy · Accountability

---

Document Reference: ISPP-001 | Version: 1.0 | Status: Approved
Classification: Confidential — Internal | Review Cycle: Annual
Frameworks: ISO 27001:2022 | ISO 27701:2019 | NIST CSF 2.0 | COSO ERM 2017 | Ghana DPA 2012 | GDPR

CONFIDENTIAL — NOT FOR PUBLIC DISTRIBUTION

1. Document Control

Field	Details
Document Title	Information Security & Privacy Policy
Document Reference	ISPP-001
Supersedes	ISP-001 (Information Security Policy) and PDP-001 (Privacy & Data Protection Policy)
Version	1.0
Status	Approved
Effective Date	2025
Owner	Managing Partner / Designated IT Lead & Data Protection Officer
Review Frequency	Annual or upon material change to the regulatory environment or IT systems
Classification	Confidential — Internal
Applicable Frameworks	ISO 27001:2022 | ISO 27701:2019 | NIST CSF 2.0 | COSO ERM 2017 | Ghana DPA 2012 (Act 843) | GDPR | Ghana Cybersecurity Act 2020 (Act 1038)

2. Purpose and Scope

2.1 Purpose

This Information Security & Privacy Policy ('the Policy') is the single governing document through which [Law Firm Name] establishes its commitment to protecting the confidentiality, integrity, and availability of all information assets within its custody, and to upholding the privacy rights of every individual whose personal data it processes.

Information security and privacy are treated as inseparable, mutually reinforcing obligations in this Policy. Effective information security is the technical and organisational foundation upon which the Firm's privacy commitments are built. Privacy governance, in turn, gives legal and ethical purpose to the Firm's security controls. Together, they form an integrated posture that meets the highest international standards and the full requirements of applicable Ghanaian law.

This Policy is designed to satisfy the requirements of ISO 27001:2022, ISO 27701:2019, NIST CSF 2.0, COSO ERM 2017, the Ghana Data Protection Act 2012 (Act 843), the GDPR (for international data subjects), and the Ghana Cybersecurity Act 2020 (Act 1038) — making it audit-ready, regulator-ready, and third-party due diligence ready from the date of adoption.

Framework alignment: ISO 27001:2022 Clause 5.2 | ISO 27701:2019 Clause 5.2 | NIST CSF GV.PO | COSO Control Environment | Ghana DPA 2012 Section 16

2.2 Scope

This Policy applies to:

- All personnel of [Law Firm Name] including partners, associates, support staff, and temporary workers
- All third-party contractors, consultants, and service providers with access to [Law Firm Name] systems or data
- All information assets owned, processed, transmitted, or stored by [Law Firm Name] regardless of format or location
- All technology systems, devices, and infrastructure operated by or on behalf of [Law Firm Name]
- All personal data processed by [Law Firm Name] whether relating to clients, staff, counterparties, or website visitors
- All physical premises from which [Law Firm Name] operations are conducted

3. Regulatory and Framework Alignment

This Policy is designed to satisfy the requirements of the following instruments:

Framework / Instrument	Relevance	Key Requirements Addressed
ISO 27001:2022	International ISMS standard	Clauses 4–10; Annex A security controls
ISO 27701:2019	Privacy Information Management System (PIMS)	Extension to ISO 27001 for data controller and processor obligations
NIST CSF 2.0	Cybersecurity risk management framework	Govern, Identify, Protect, Detect, Respond, Recover functions
COSO ERM 2017	Enterprise risk and internal control framework	Control Environment, Risk Assessment, Control Activities, Monitoring
Ghana DPA 2012 (Act 843)	National data protection legislation — mandatory	DPC registration; eight principles; data subject rights; breach notification
Ghana Cybersecurity Act 2020	National cybersecurity obligations — mandatory	Security of digital systems; incident reporting to Cyber Security Authority
GDPR (EU) 2016/679	Applies where EU data subjects are involved	Lawful basis; DPIA; data subject rights; cross-border transfers
Legal Professional Privilege	Professional conduct obligation	Confidentiality of all client communications and legal advice

4. The Two Pillars of This Policy

This Policy is organised around two complementary pillars. Each pillar has its own objectives, principles, and controls — but they share common governance, roles, and operational mechanisms.

PILLAR ONE — INFORMATION SECURITY
Protecting the confidentiality, integrity, and availability of all information assets against cyber threats, unauthorised access, operational failure, and physical risk. Governed by ISO 27001:2022 and NIST CSF 2.0.

PILLAR TWO — PRIVACY & DATA PROTECTION
Ensuring that all personal data is processed lawfully, fairly, and transparently — and that the privacy rights of clients, staff, and all data subjects are respected, protected, and upheld. Governed by Ghana DPA 2012, ISO 27701:2019, and GDPR.

5. Information Security — Objectives and Principles

ISO 27001:2022 Clause 6.2 | NIST CSF GV.PO | COSO Control Environment

5.1 Security Objectives

Objective	Measurement	Target
Protect client and firm data from unauthorised access	Access control audit findings	Zero critical findings per annual review
Maintain availability of critical systems	Unplanned system downtime	Less than 4 hours per year
Ensure all staff complete security awareness training	Training completion rates	100% annually
Manage third-party security risks	Vendor risk assessments completed	100% of critical vendors assessed
Respond to security incidents within defined timeframes	Incident response SLA compliance	100% within defined SLAs
Ensure regulatory compliance is maintained	Compliance review outcomes	Zero unresolved critical compliance gaps

5.2 Core Security Principles

Confidentiality

Information is accessible only to those authorised to access it. Client data, legal files, financial records, and personal data are classified and protected commensurate with their sensitivity level.

Integrity

Information is accurate, complete, and protected against unauthorised modification at all stages of processing, transmission, and storage.

Availability

Information and systems are available to authorised users when required. Business continuity and disaster recovery arrangements ensure resilience against disruption.

Accountability

All access to and actions upon information assets are attributable to an identifiable individual. Audit trails are maintained for all critical system and data interactions.

6. Privacy & Data Protection — Objectives and Principles

Ghana DPA 2012 Section 17 | ISO 27701:2019 Clause 7.2 | GDPR Article 5 | NIST Privacy Framework

6.1 DPC Registration

[Law Firm Name] is registered with the Data Protection Commission of Ghana (DPC) as a data controller in accordance with Section 16 of the Ghana Data Protection Act 2012. Registration is maintained as current and renewed annually. A designated Data Protection Officer (DPO) or Privacy Contact is appointed with responsibility for overseeing compliance with this Policy.

Detail	Information
Data Controller	[Law Firm Name]
DPC Registration Status	Registered
DPC Registration Number	[To be inserted]
Data Protection Contact	Managing Partner / DPO
Website Privacy Notice	Published at [www.lawfirmwebsite.com/privacy]

6.2 The Eight Data Protection Principles

All personal data processed by the Firm is handled in compliance with the eight data protection principles under the Ghana DPA 2012:

Principle	Obligation	Firm Implementation
1. Lawfulness	Processing must have a lawful basis	Consent or legal obligation documented for all processing activities
2. Specified Purpose	Data collected for specified, explicit, and legitimate purposes	Processing Register maintained with stated purpose per data category
3. Compatibility	Data not used for incompatible purposes	New uses assessed against original purpose before implementation
4. Adequacy	Data must be adequate, relevant, and not excessive	Data minimisation applied; only necessary data collected

Principle	Obligation	Firm Implementation
5. Accuracy	Data must be accurate and kept up to date	Annual data review; corrections actioned within 5 business days
6. Retention	Data not retained longer than necessary	Data Retention Schedule maintained and enforced
7. Security	Appropriate technical and organisational measures applied	ISO 27001-aligned controls; Microsoft 365; encrypted communications
8. Accountability	Controller must demonstrate compliance	Processing Register; training records; DPC registration maintained

7. Roles and Responsibilities

ISO 27001:2022 Clause 5.3 | ISO 27701:2019 Clause 5.3 | NIST CSF GV.RR | COSO Principle 3

Role	Information Security Responsibility	Privacy Responsibility
Managing Partner	Ultimate accountability for ISMS; approves Policy and exceptions; receives security reports	Ultimate accountability for DPA compliance; approves DPIAs; receives DPC correspondence
IT Lead / Security Officer	Day-to-day ISMS management; access controls; incident coordination; patch management	Maintains Processing Register; manages vendor DPAs; coordinates breach notification
Data Protection Officer (DPO)	Supports ISMS compliance; monitors control effectiveness	Oversees DPA 2012 compliance; advises on DPIAs; handles data subject requests
All Staff	Comply with this Policy; report security incidents; complete security training	Handle personal data only as authorised; report suspected data breaches; complete DPA training
Third-Party Providers	Meet contractually imposed security standards; notify Firm of incidents	Process personal data only per Firm instructions; maintain data processing agreements

8. Information Asset and Data Management

ISO 27001:2022 Annex A 5.9–5.12 | ISO 27701:2019 Clause 7.2 | NIST CSF ID.AM

8.1 Asset Classification

All information assets are classified as follows:

Classification	Description	Handling Requirements
Confidential	Client data, legal advice, personal data, financial records, privileged communications	Encrypted at rest and in transit; need-to-know access only; not transmitted via unencrypted channels
Internal	Internal procedures, staff records, operational data	Restricted to authorised staff; not shared externally without authorisation
Public	Published firm information, website content	No special handling required; reviewed before publication

8.2 Personal Data Categories Processed

Category	Data Types	Lawful Basis
Client Data	Name, contact details, ID documents, financial and legal matter data, special categories where relevant to the legal matter	Contract performance; legal obligation; consent where required
Staff Data	Name, contact details, employment history, payroll, NID, tax data, performance records	Contract; legal obligation
Website Visitors	IP address, browser data, cookies, contact form submissions	Consent (GDPR-compliant cookie notice published)
Third Parties	Counterparties, witnesses, beneficiaries — data received in course of legal matters	Legal obligation; legitimate interests; legal claims

8.3 Data Retention

The Firm maintains a Data Retention Schedule specifying retention periods for each data category. Key periods include:

Data Category	Retention Period	Basis
Client legal files (active matters)	Duration of engagement plus 7 years	Legal professional obligation; limitation periods
Client KYC / identity documents	5 years after end of relationship	AML Act 2008 (Act 749)
Staff employment records	Duration of employment plus 6 years	Employment Act; tax obligations
Financial and billing records	7 years	Companies Act; tax legislation
Website enquiry data	12 months unless ongoing relationship	Consent-based retention

Data Category	Retention Period	Basis
Email correspondence	Per underlying matter retention period	Legal professional obligation

Personal data is securely disposed of at the end of its retention period. Physical documents are cross-cut shredded. Electronic data is permanently deleted, and decommissioned storage media is securely wiped or physically destroyed.

9. Access Control

ISO 27001:2022 Annex A 5.15–5.18 | ISO 27701:2019 Clause 6.4 | NIST CSF PR.AA | COSO Control Activities

- All user accounts are individually assigned and must not be shared under any circumstances
- Strong passwords or passphrases are mandatory on all systems and accounts
- Multi-factor authentication (MFA) is required for Microsoft 365 and all cloud-based services
- The principle of least privilege applies — access is granted only to the minimum required for the role
- Access rights are reviewed at least annually and immediately upon change of role or departure
- Administrative privileges are restricted to the designated IT Lead only
- Remote access is permitted only via secured, encrypted channels
- All access to personal data and client files is logged and subject to periodic audit review
- Data subject access to their own personal data is managed through the formal subject access request process

10. Technical Security Controls

ISO 27001:2022 Annex A 8.1–8.34 | NIST CSF PR | CIS Controls v8 | COSO Control Activities

10.1 Endpoint and Device Security

- Licensed antivirus and endpoint protection software active on all firm devices with real-time scanning and auto-update
- Windows operating system and all applications updated automatically; critical patches applied within 48 hours
- Full-disk encryption (BitLocker or equivalent) on all laptops containing firm data
- Screen auto-lock enabled after 5 minutes of inactivity on all devices
- USB and removable media usage restricted and subject to prior IT Lead authorisation
- Only authorised software is permitted on firm devices; installation rights restricted to IT Lead

10.2 Network Security

- Router and switch infrastructure with firewall enabled at network perimeter and on all endpoints
- Wi-Fi encrypted using WPA3 or WPA2 as a minimum; guest network fully isolated from internal network
- Guest and visitor devices have no access to firm systems or data
- DNS filtering active to block known malicious domains

10.3 Microsoft 365 Cloud Security

- MFA enforced on all Microsoft 365 accounts without exception
- Conditional access policies restricting access from unmanaged or high-risk devices and locations
- Data Loss Prevention (DLP) policies configured to detect and restrict sharing of sensitive data
- Audit logging enabled; administrator activities and user sign-ins retained and monitored
- Anti-phishing, safe links, and safe attachments configured through Microsoft Defender for Office 365
- Microsoft 365 cloud backup or equivalent third-party backup service operational

10.4 Email Security

- Transport Layer Security (TLS) encryption for all email in transit
- DMARC, DKIM, and SPF records configured to prevent domain spoofing and impersonation
- Spam and malware filtering with quarantine management
- Confidential attachments transmitted externally are password-protected or encrypted where appropriate

10.5 Multifunction Device (Print/Scan/Fax)

- Canon MFD access-controlled; network print function isolated from general data traffic where technically feasible
- Print queues cleared after each use; sensitive documents not left unattended in output trays
- Scanned documents containing personal data transmitted only to authorised destinations

11. Physical and Environmental Security

ISO 27001:2022 Annex A 7.1–7.14 | NIST CSF PR.AA-05 | COSO Risk Assessment

- Office premises are access-controlled with visitor management procedures in place
- Network equipment (router and switch) is housed in a secured location inaccessible to unauthorised persons
- Laptop devices are cable-locked or stored securely when not in use
- Clean desk and clear screen policies are enforced to prevent inadvertent disclosure of sensitive information

- Physical documents containing confidential or personal data are securely stored in locked cabinets when not in use
- Confidential physical documents are disposed of by cross-cut shredding

12. Data Subject Rights

Ghana DPA 2012 Sections 23–27 | GDPR Articles 15–22 | ISO 27701:2019 Clause 7.3

The Firm recognises and upholds the following rights of all data subjects:

Right	Description	Response Timeframe
Access	Request a copy of personal data held by the Firm	Within 30 days of verified request
Rectification	Request correction of inaccurate or incomplete personal data	Within 5 business days
Erasure	Request deletion where no lawful basis for continued retention exists	Within 30 days; subject to legal retention obligations
Object	Object to processing based on legitimate interests or for direct marketing	Immediately for marketing; assessed for other grounds within 30 days
Restrict Processing	Request limitation of processing in specific circumstances	Within 30 days of verified request
Data Portability	Receive personal data in a structured, machine-readable format	Within 30 days of verified request
Withdraw Consent	Withdraw consent at any time where processing is consent-based; does not affect prior processing	Immediately upon request

Data subject requests are submitted in writing to the Firm's Data Protection Contact. The Firm verifies the identity of the requestor before processing any subject access request.

13. Cross-Border Data Transfers

Ghana DPA 2012 Sections 43–44 | GDPR Chapter V | ISO 27701:2019 Clause 7.5

The Firm does not transfer personal data outside Ghana without ensuring adequate protection is in place. Where international transfers are required — including use of Microsoft 365 cloud services or international legal matters — the Firm relies on:

- Microsoft's standard contractual clauses and data processing agreements for cloud-hosted personal data
- Adequacy assessments for jurisdictions receiving personal data
- Explicit client consent for transfers where required under Ghana DPA 2012
- Legal obligation or defence of legal claims where applicable

The website collects data through GDPR-compliant consent mechanisms. Where data subjects are located in the EU or EEA, GDPR standards are applied as the higher threshold.

14. Third-Party and Vendor Security

ISO 27001:2022 Annex A 5.19–5.22 | ISO 27701:2019 Clause 6.12 | NIST CSF GV.SC | COSO Risk Assessment

Third-party service providers with access to Firm data or systems must meet security and privacy standards equivalent to those applied internally. The Firm's third-party management approach includes:

- A Data Processing Agreement (DPA) executed before any personal data is processed by a third party
- Security requirements embedded in all third-party contracts and service agreements
- Vendors assessed against a defined vendor risk questionnaire prior to engagement
- Annual vendor security and compliance review on contract renewal
- Third-party access restricted to the minimum necessary; monitored; terminated on contract expiry
- Sub-processing by vendors restricted and subject to prior written approval

15. Incident Management and Personal Data Breach Response

ISO 27001:2022 Annex A 5.24–5.28 | ISO 27701:2019 Clause 6.11 | NIST CSF RS | COSO Monitoring

All information security incidents and suspected personal data breaches are reported immediately to the Designated IT Lead and Data Protection Contact. An incident is defined as any event that compromises or threatens the confidentiality, integrity, or availability of information assets, or the privacy of personal data.

Phase	Action	Timeframe
Detection & Reporting	Staff report suspected incidents to IT Lead via defined channel	Immediately upon detection
Assessment	IT Lead and DPO assess severity, scope, and whether personal data is involved	Within 2 hours
Containment	Immediate steps taken to limit the spread or impact of the incident	Within 4 hours
DPC Notification	Notify Data Protection Commission if personal data breach confirmed	Within 72 hours of confirmed breach
Data Subject Notification	Notify affected individuals if breach poses high risk to their rights and freedoms	Without undue delay
CSA Notification	Notify Cyber Security Authority for significant cybersecurity incidents as required under Act	Per CSA prescribed timeframe

Phase	Action	Timeframe
	1038	
Recovery	Restore systems and data from clean backups; verify integrity	Per BCP/DRP timelines (DRBCP-001)
Post-Incident Review	Root cause analysis; update controls; document in Breach Register; report to Managing Partner	Within 14 days of resolution

16. Security Awareness and Training

ISO 27001:2022 Annex A 6.3 | ISO 27701:2019 Clause 6.4 | NIST CSF PR.AT | COSO Control Environment

All staff with access to firm systems or personal data receive integrated security and privacy awareness training covering:

- The requirements of the Ghana Data Protection Act 2012 and the Firm's obligations as a data controller
- Information security threats — phishing, social engineering, malware, password security
- Correct handling and classification of confidential and personal data
- Clean desk, clear screen, and secure printing practices
- How to identify, contain, and report a security incident or personal data breach
- Data subject rights and how to handle access requests
- Secure use of Microsoft 365 and other approved tools

Training is completed on induction and refreshed annually. Completion is documented in the Firm's training register and reported to the Managing Partner.

17. Business Continuity and Information Security

ISO 27001:2022 Annex A 5.29–5.30 | ISO 22301:2019 | NIST CSF RC

The Firm maintains a Disaster Recovery and Business Continuity Plan (DRBCP-001) as a standalone document. Information security and privacy obligations continue during and after any disruptive event. Key commitments embedded in this Policy include:

- Critical data backed up daily to a secure, geographically separated location via Microsoft 365 cloud backup
- Recovery Time Objective (RTO): Critical systems restored within 24 hours
- Recovery Point Objective (RPO): Maximum 24-hour data loss tolerance
- Personal data protection obligations — including DPC breach notification — remain active during any disruption
- Business Continuity Plans tested at least annually through tabletop exercises and documented in DRBCP-001

18. Policy Compliance and Enforcement

Compliance with this Policy is mandatory for all persons within its scope. Breaches may result in disciplinary action up to and including termination of employment or contract. Serious breaches involving personal data may be reported to the Data Protection Commission. Cybersecurity breaches may be reported to the Cyber Security Authority.

Policy exceptions may be granted by the Managing Partner in writing. All exceptions are documented, time-limited, and subject to compensating controls and senior review.

This Policy is reviewed annually by the Managing Partner, IT Lead, and Data Protection Officer. It is also reviewed following any material security incident, significant data breach, change to the Firm's IT environment, or relevant regulatory change. All revisions are documented in the version history.

19. Review and Approval

Field	Details
Policy Owner	Managing Partner / IT Lead / Data Protection Officer
Approved By	Managing Partner
Date of Approval	_____
Next Review Date	_____ (12 months from approval)
Version History	v1.0 — Initial issue; consolidates ISP-001 and PDP-001

Comprehensive Framework Alignment Summary

This Policy satisfies the requirements of: ISO 27001:2022 (Clauses 4–10; Annex A controls including access control, physical security, operations, communications, incident management, compliance); ISO 27701:2019 (Privacy Information Management System — data controller and processor obligations, data subject rights, cross-border transfers); NIST Cybersecurity Framework 2.0 (Govern, Identify, Protect, Detect, Respond, Recover); NIST Privacy Framework 1.0 (Identify-P, Govern-P, Control-P, Communicate-P, Protect-P); COSO Enterprise Risk Management Framework 2017 (Control Environment, Risk Assessment, Control Activities, Monitoring Activities); Ghana Data Protection Act 2012 Act 843 (all data controller obligations — DPC registration, eight principles, data subject rights, breach notification, cross-border transfers, third-party processors); Ghana Cybersecurity Act 2020 Act 1038 (organisational cybersecurity obligations, incident reporting); GDPR EU 2016/679 (applied for EU/EEA data subjects and international transfers as the higher threshold).